Risk Management for Open-Weight Models in Enterprise

A Joint Microsoft and NVIDIA Publication

October 2026

Abstract

Open-weight models are AI models that any individual or enterprise can download, inspect, modify, and run on their own infrastructure. Weight openness alone does not determine an AI system's risk. Risk depends on the model, use case, deployment, and safeguards. While open- and closed-weight models share underlying risks, the realized risks differ based on a model's distribution method, access, and deployment, which affects who is responsible for managing and governing those risks. This paper proposes enterprise-grade risk management guidance for the safe, secure, and trustworthy deployment and use of open-weight models. It introduces a risk taxonomy to surface potential risks and offers risk management guidance, derived from ISO/IEC standards and the NIST AI Risk Management Framework, for identifying, evaluating, mitigating, and monitoring those risks. An example illustrates how enterprises could apply this guidance in practice. This is the first paper in a series of Microsoft and NVIDIA joint papers on end-to-end governance of open-weight model deployment.

Keywords: open-weight models; AI risk management; risk taxonomy; AI governance; AI safety; AI security; model evaluation; red teaming; NIST AI RMF; ISO/IEC 23894; ISO/IEC 42001; enterprise AI deployment

Contents

1. Executive Summary 3
2. Definitions and Scope 4
2.1 Existing Frameworks 4
2.2 Risk Definition and Scope 4
3. Risk Taxonomy 5
3.1 Overview 5
3.2 Structure 5
3.3 Risk Categories 6
3.4 Current Risk Taxonomy & Future Updates 7
4. Risk Management Process Guidance 7
4.1 Overview 7
4.2 Scope, Context, and Criteria 8
4.3 Risk Assessment 9
4.4 Evaluations 9
4.5 Risk Mitigation 11
4.6 Monitoring 12
5. An Example of an Enterprise Use Case 12
6. Conclusion 14
Appendix 16
Risk Categories Mapped to Evaluations 16
Risk Definitions 18

1. Executive Summary

Open-weight models are AI models that any individual or enterprise[1] can download, inspect, modify, and run on their own infrastructure. Open-weight models differ from closed-weight models, which are proprietary, not available to the public for download or inspection, and are usually only accessible through third-party infrastructure like hosted application programming interfaces (APIs).

Open-weight models are foundational to making advanced AI more accessible, adaptable, and cost-effective. **The availability of both open-weight and closed-weight models lets every enterprise match the right model to the right job at the right cost, giving them greater control over the benefits and risks of the technology they rely on and deploy to end users.**

Weight openness alone does not determine an AI system's risk. Risk depends on the model, use case, deployment, and safeguards. Both open- and closed- weight models share underlying risks that depend on model capability, use case context, and controls. However, the realized risks will differ based on a model's distribution method, access, and deployment, and affect how and who is responsible for managing and governing those risks. Unlike closed-weight models, which frequently come with composed guardrails, security monitoring, caching and other services, open-weight models are often distributed as bare checkpoints and require additional integrations for parity. The controls are largely the same, but who provides those controls will differ along with the transparency provided.

Model access and deployment are separate choices. Open-weight models can also be deployed through managed platforms, with responsibility for controls depending on the service and configuration. As a result, open-weight model deployers may need to take additional measures to implement controls across the model, runtime, harness, and application layers. Robust deployments of either type balance the effectiveness and utility of controls at each layer while also assuming responsibility for lifecycle management, including ongoing risk management through monitoring, guardrail, and system updates. Model evaluation alone does not establish the safety of an agent or application; enterprises must also assess permissions, data access, connected tools, runtime behavior, and operational controls in the deployed system.

This paper proposes enterprise-grade risk management guidance for the safe, secure, and trustworthy deployment and use of open-weight models. It includes the following:

1. A risk taxonomy to surface potential risks;
2. Risk management guidance derived from third-party, authoritative sources including the International Organization for Standardization's (ISO) standards to manage the risks of AI and the U.S. National Institute of Standards and Technology's (NIST) AI Risk Management Framework (AI RMF), which outlines processes to identify, evaluate, mitigate, and monitor risks; and
3. An example to illustrate how enterprises could apply this guidance to manage risks in their scenarios.

This initial publication presents a conceptual framework for enterprises to begin managing risks associated with open-weight models. It is the first paper in a series of Microsoft and NVIDIA joint papers on end-to-end governance of open-weight model deployment. This publication is a starting point for safely managing open-weight model risks. Future

[1] "Enterprise" includes commercial enterprises, governments, nonprofits, educational institutions, civil society, start-ups, and other collective organizations.

publications will provide guidance on risk management across the model, runtime, harness, and application layers, along with technical guidance on risk evaluation and mitigation. As the AI landscape evolves, we will update these resources to address enterprises' emerging needs.

2. Definitions and Scope

2.1 Existing Frameworks

This paper describes how existing risk management practices can be applied to open-weight models, which will build the foundation to further extend to end-to-end risk management across the model, runtime, harness, and application layers. This paper serves as an extension, not replacement, for these standards.

Many enterprises already operate a cybersecurity risk program built on the NIST Cybersecurity Framework (CSF) 2.0 and ISO/IEC 27001, with a risk process inherited from ISO 31000. Those programs establish the preconditions upon which the guidance depends:

- An asset inventory[2],
- Defined operational and business context[3], and
- Approved risk tolerances and criteria[4].

This paper builds directly on that foundation:

- ISO/IEC 23894 adapts ISO 31000 to AI,
- ISO/IEC 42005 provides additional guidance on performing AI system impact assessment,
- ISO/IEC 42001 is to AI management systems what ISO/IEC 27001 is to information security management systems, and
- NIST's AI Risk Management Framework (AI RMF) is the AI counterpart to the CSF, with NIST's draft Cyber AI Profile (IR 8596) now supplying the explicit bridge between them.

An enterprise's existing inventory, context, and tolerance processes remain authoritative; what changes is their reach in the use of open-weight models.

2.2 Risk Definition and Scope

In the context of AI risk management, we can think of risk as the likelihood of an adverse event combined with the magnitude of its consequences. Open- and closed-weight models share common risks. Microsoft and NVIDIA have jointly developed a shared taxonomy to capture key risks that should be directly managed by enterprises. **Because the goal of this paper is to help enterprises operationalize risk management within their organizations, the taxonomy is only scoped to a non-exhaustive set of risks that can be detected in AI systems and that can be directly managed by enterprises.** Specifically, the section below describes risks that are in or out of scope.

[2] CSF 2.0 Identify: Asset Management (ID.AM-02); ISO/IEC 27001 Annex A 5.9
[3] CSF 2.0 Govern Organizational Context (GV.OC); ISO/IEC 27001 4.1-4.3
[4] CSF 2.0 Govern Risk Management Strategy (GV.RM); ISO 31000 6.3

In Scope

- Risks that may be relevant to open- and/or closed-weight models.
- Risks that materialize through AI system outputs, interactions, or actions, and can therefore be detected, assessed, and managed by enterprises during deployment and use.
- Risks arising from factors such as AI system malfunction, user misuse (including malicious use), adversarial attacks, or other failures that influence AI system behavior and outcomes.

Out of Scope

- Systemic and societal risks that arise from the broader deployment and adoption of AI that are not managed by an individual enterprise.
- Performance or operational considerations, such as costs and latency. While these are important considerations, they are not the focus for this guidance.
- Organizational governance requirements and risk tolerance (NIST SP 800-37 RMF and SP 800-30).

These exclusions reflect scope, not importance. Infrastructure security, access management, and business continuity are not unique to AI and are already governed by established frameworks such as NIST SP 800-53, the NIST Risk Management Framework, and ISO/IEC 27001. Enterprises should extend them to cover their own model artifacts and inference infrastructure. Cost, latency, and throughput are service-quality properties that need to be balanced with risks. Observability, mitigation techniques, and provenance are examples of risk mitigation and are addressed in the process described in Section 4.

3. Risk Taxonomy

3.1 Overview

The risk taxonomy provides a foundation for risk management by establishing a shared vocabulary for how risks can arise in AI systems. It organizes risks into risk categories and risk types, helping enterprises identify relevant risks and map them to appropriate evaluations and mitigations (which will be discussed in future publications). The taxonomy is not a policy or a checklist. It does not define an enterprise's risk-tolerance criteria or determine deployment decisions. Instead, it is a resource to be operationalized within a broader risk management framework.

3.2 Structure

The taxonomy organizes risks into the following structure:

- **Risk Category (L1):** High-level grouping to organize risk types.
- **Risk Type (L2):** A more granular breakout of risks that may arise under each broad Risk Category (L1). For the purposes of risk management, functional owners and subject-matter experts are assigned at the Risk Type (L2) level. Evaluations and mitigations are also mapped to the L2 risks.

An individual **risk** is the composite measure of the likelihood of an event occurring and the magnitude or degree of the consequences of that event. It is assessed based on the deployment context of L2 risks and the efficacy of mitigations to remediate those risks. Understanding the **risk source**, the point in the AI lifecycle or system architecture at which a risk originates (e.g., training data, model weights and

post-training, the inference serving layer) helps inform the appropriate mitigations and layers to deploy those mitigations.

The hierarchy is flexible. A single L2 risk may arise from multiple risk sources, and a single risk source[5] could lead to risks across multiple L1 risk categories. For cross-category risks, the taxonomy assigns a primary L1 category for reporting and cross-references to the others. This approach supports multidisciplinary assessment, accounts for differences in severity across perspectives, and enables mitigation at different layers of the technology stack.

3.3 Risk Categories

The following section describes the broad L1 risk categories used to organize all L2 risk types.

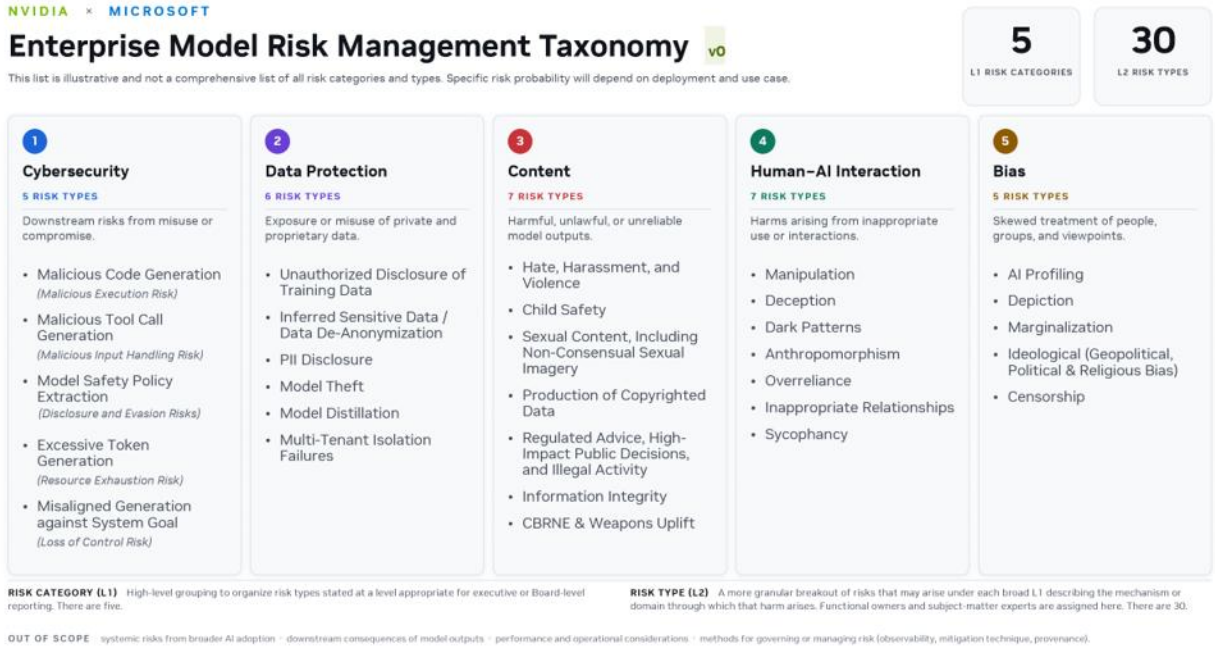
1. **Cybersecurity:** Risks from misuse or compromise of an AI system that may result in security threats to confidentiality, integrity, or availability.
2. **Data Protection:** Risks from the unauthorized or unintended use, inference, or disclosure of data. This includes data never directly disclosed by a subject but derived by the system (inferred sensitive attributes, de-anonymization), and use of data beyond the rights granted for it (intellectual property, licensing, consent, purpose limitation).
3. **Content:** Risks from the production of harmful content.
4. **Human–AI Interaction:** Risks from inappropriate use or interactions between a human and AI system.
5. **Bias:** Risks from systematic difference in treatment of certain objects, people, or groups relative to others.

[5] Risk Source: internal/external elements that possess the capability, intent, or vulnerability to trigger a compromising event.

3.4 Current Risk Taxonomy & Future Updates

As the risk landscape continues to evolve, this taxonomy will continue to be updated to capture emerging L2 risks while the broader L1 categories are intended to remain stable. The current risk taxonomy is shown below.

Figure 1: Risk Taxonomy



Please see the Appendix for risk definitions, as well as evaluations mapped to a select set of risks described in the risk taxonomy.

Also note that techniques, such as jailbreaking, prompt injections, adversarial suffixes / Greedy Coordinate Gradient attacks, token-level and Unicode tricks, etc. that could lead to the emergence of cybersecurity risks, are excluded from the taxonomy.

4. Risk Management Process Guidance

4.1 Overview

Our guidance is for enterprises to prioritize risks using the risk taxonomy described in Section 3, and to converge on their own assessment structured around their scoped use case of open-weight models and organizational risk tolerance. While this paper does not assume the enterprise developed the underlying model, it presumes an enterprise seeking to diligently deploy trustworthy AI models.

This guidance applies ISO/IEC 23894's risk management process to enterprise integrations and operation of AI models and aligns with the NIST AI RMF Map, Measure, and Manage functions. It may be used independently or within existing governance and assurance processes, such as an ISO/IEC 42005 system impact assessment.

The guidance covers these risk management processes:

1. **Scope, Context, and Criteria (ISO/IEC 23894, 6.3):** Define the scope of deployment and establish the internal and external context of your enterprise to assess risks.
2. **Risk Assessment (ISO/IEC 23894, 6.4):** Within your deployment context and use cases, identify and prioritize risks. Adapt the taxonomy to your deployment. Assess potential consequences, likelihood, affected stakeholders, existing controls, and uncertainty. Assign owners who can act on the findings. ISO/IEC 42005 impact assessments require the same inputs, allowing teams to use one analysis for both purposes.
3. **Evaluations (ISO/IEC 23894, 6.4.4):** For applicable risks, enterprises should run evaluations to produce risk evidence and measurements (i.e., the propensity of the risk occurring in the deployment scenario). Decision-makers can use evaluation results to prioritize risk mitigation.
4. **Risk Mitigation (ISO/IEC 23894, 6.5):** For prioritized risks, implement mitigations to address risks. Re-run evaluations to assess the efficacy of mitigations.
5. **Monitoring (ISO/IEC 23894, 6.6):** Implement post-deployment monitoring to detect problems at run-time. Re-evaluate after material changes to the model, configuration, controls, or user population. This is the same cadence ISO/IEC 42005 expects for maintaining an impact assessment.

The following sections detail these processes and recommend techniques and resources for managing open-weight-model risks.

4.2 Scope, Context, and Criteria

Before identifying and evaluating risks, enterprises should establish an assessment scope and understand deployment context. This includes the model's provenance, development history, known capabilities and limitations, intended uses, and reasonably foreseeable misuse. Acceptance criteria should be defined and translated into concrete evaluation scenarios and rules for judging outcomes. Evaluation options include calibrated LLM judges, trained feedback models, curated reference sets, and structured human feedback and controlled A/B testing. Select methods based on their ability to detect relevant failures, the cost of developing and running them, the intended evaluation frequency, and the effort required to keep them aligned with policy changes.

Acceptance criteria should reflect well-defined applicable legal and contractual requirements as well as internal policy and should be operational before results are interpreted.

Context should be built first. Start by recording information about the surrounding deployment: the systems that supply the model's inputs and consume its outputs; the data it receives; and how people will interpret and act on what it returns. This establishes what model-layer findings do and do not cover. Risks arising within those surrounding components are assessed by their owners.

Modifications affect safety measures and core capabilities differently. Safety behaviors are often the more fragile of the two. Changes to weights, fine-tuning, model merging, quantization, configuration, and modified redistribution can degrade safeguards while leaving task performance intact. So, treat safety and capability as separate questions rather than inferring one from the other.

Evaluate throughout the development lifecycle, not just at the end. Update evaluations as criteria, policies, or intended uses change. Intermediate checkpoints and related model versions are frequently the most effective points to intervene, as mitigations applied there cost less than controls added afterward. Findings from earlier releases can inform subsequent assessments, but the assessment of record must use the applicable criteria and evaluation methods for the specific version and configuration you deploy.

4.3 Risk Assessment

Risk taxonomies support identification and prioritization of risks particular to the organization and use cases. However, they are neither exhaustive nor a substitute for context-specific assessment. Additional risks may come from deployment conditions, model modifications, architecture, threats, legal obligations, or organizational requirements.

Assessments should draw on evaluations, red teaming, testing, operational experience, incident data, threat intelligence, vulnerability disclosures, relevant published research, and public information.

Propensity and likelihood are established differently and should not be conflated. Propensity is the model's tendency to exhibit a behavior under test. Evaluations estimate this tendency within the scope of those conditions. Likelihood is what that propensity becomes once deployment exposure, user population, and adversary motivation are applied. It is a property of the deployment and needs to be estimated in advance. Reporting propensity as likelihood overstates what an evaluation establishes.

Record the measured propensity, the estimated likelihood, the potential consequences and their severity, and the uncertainty in each. Then log the affected stakeholders, the existing controls, and the reliability of the underlying evidence. Compare the result against the criteria established in 4.2 to determine significance, priority, and escalation. Finally, state how each prioritized risk will be accepted, mitigated, transferred, or avoided.

Two elicitation techniques operate within this process. ISO/IEC 23894 provides the risk management process itself. Within it, threat modeling and failure modes and effects analysis (FMEA) surface different kinds of risk. Use threat modeling where a risk requires an adversary to materialize. It identifies actors, attack vectors, vulnerabilities, misuse scenarios, and abuse pathways. Use FMEA where a risk materializes without an adversary. FMEA are ways a model produces unsupported, biased, or unsafe output in ordinary use. Select the technique by whether an adversary is required, not by taxonomy category. For example, Content contains both jailbreaking and groundedness, and Data Protection contains both unauthorized disclosure of data and use of intellectual property.

Both techniques take the deployment context characterized in 4.2 as input, and both are scoped to the model layer. Model layer threats include model modifications such as fine-tuning, merging, quantization, redistribution, configuration changes, and the possibility that prior safety mitigations were altered, removed, or bypassed. Threats to hosting infrastructure are managed under existing enterprise security controls. Threats from connected tools, external services, and downstream integrations are context and should also be assessed, but at the harness and application layers, which will be addressed in subsequent papers.

Enterprises should maintain assessments across the lifecycle and update them when capabilities, deployment conditions, threats, legal requirements, or operational conditions change. Evaluations, monitoring, incidents, vulnerability disclosures, and deployment experience should feed ongoing risk management.

4.4 Evaluations

After identifying and analyzing specific risks and their likelihood, severity, and characteristics, the next step is analyzing the impact of mitigations and whether residual risk meets acceptance criteria. Each evaluation targets a specific risk and produces evidence that can be interpreted against the relevant criteria and potential consequences. The evaluation supplies the measurement. Whether that risk level

is acceptable is decided separately, against the criteria established when you defined scope. Before testing, define the objective, the risk under test, the target of evaluation, the metrics and the evidence supporting them, and the decision criteria. Turn policy requirements into test cases and scoring rules. Choose evaluation methods, such as calibrated LLM judges, reference sets, or human review, based on reliability, cost, evaluation frequency, and ease of updating as policies change.

Testing regimes follow from the risk categories that apply to the deployment. Content and Bias risks are addressed primarily through benchmarks and automated suites and reported with disaggregation across the languages and populations served. Cybersecurity risks call for adversarial testing and security review. Human-AI Interaction risks are not observable from model outputs alone and require human-factors testing with representative users. Data Protection risks call for extraction and leakage testing across prompts, outputs, and logs.

Adversarial testing and expert red teaming serve different purposes and should not substitute for one another. Adversarial testing applies known techniques systematically. It is automatable, repeatable, and suited to regression detection. Expert red-teaming is open-ended human exploration aimed at failure modes no suite yet encodes. It is not repeatable by design. Document its scope, method, and findings, and convert confirmed findings into repeatable tests so discovery feeds the measured set. High-severity risks warrant both, together with independent evaluation.

Because an open-weight model may be modified, repackaged, or redistributed before acquisition, upstream safeguards may be absent or ineffective. Due diligence and testing should cover artifact integrity, supply-chain risks, undocumented changes, malicious or unsafe fine-tuning, safeguard removal, and integration with unanticipated tools or capabilities. They should verify that external controls remain effective as model behavior or configuration changes.

Establish provenance before behavior. Cryptographic signing, such as OMS Model Signing, verifies that the artifact you received is the one the provider published, including its components and the claims in its model card. This is a deterministic check and a foundational control against undocumented modification in the supply chain. Evaluation cannot substitute for it. No volume of behavioral testing establishes what an artifact is, only how it behaves. Where signatures are unavailable, record the unverified integrity as an open risk rather than treating evaluation results as closing it.

Enterprises should document evaluation datasets, prompts, scoring methods, evaluation tooling, and model and system configurations. That record is what makes a result repeatable, comparable, and usable as evidence for a deployment decision. Enterprises should distinguish evidence and record limitations and uncertainty. This includes coverage, measurement error, evaluator disagreement, benchmark contamination, test-data leakage, reproducibility constraints, and gaps between tests and operations.

Microsoft Foundry provides built-in evaluators and support for custom evaluation criteria, automated red teaming to probe safety risks, and configurable content-safety controls for harmful inputs and outputs and prompt attacks. Confirm which controls your deployment supports, including preview status, and complement them with application testing, monitoring, and human oversight.

Integrating repeatable, continuous evaluation capability like NeMo Gym for comparing candidates is critical. Then the next step is validating selected models and assessing material system changes. This

is particularly important when weights, tokenizers, adapters, quantization, fine-tuning, model merges, packaging, inference runtimes, or upstream safeguards change.

Enterprises may use operational data, monitoring, incidents, vulnerability disclosures, newly identified misuse methods, and updated developer or distributor information to revise test suites and reassess risk. Where feasible, suites should run consistently across candidates while supporting risk-specific tests, scenarios, and thresholds. Finally, appropriate technical, domain, safety, security, legal, and operational experts should review results and communicate them to risk owners and deployment decision makers.

For material issues attributable to a model or distribution package, it's important to promptly assess exposure and controls and, when appropriate, report to the relevant developer or distributor.

See the Appendix for additional resources to evaluate specific risks.

4.5 Risk Mitigation

Once evaluations have been integrated, enterprises should assess and treat models as components of broader AI systems. They can consider the intended use, operating environment, business processes, and governance controls.

Risk treatments should account for:

- the intended use and deployment context;
- the likelihood and severity of potential harms;
- the availability and effectiveness of technical and organizational controls;
- the degree of human oversight required;
- applicable legal, regulatory, contractual, and organizational requirements; and
- the consequences of control failure.

The same capability may require different treatments depending on the context. Treatments should be proportionate to the impact of erroneous, unsafe, or inappropriate outputs. Transcription errors, for example, may be tolerable in some educational settings but significant in healthcare, legal, financial, or corporate governance uses.

One of the primary mitigations an organization might consider is weight modification. Another is changing controls that can operate in the runtime, application, or process. These approaches are not mutually exclusive, and the choice among them determines which prior evaluations remain valid and which safeguards the enterprise must sustain itself. In all instances, enterprises should retain a verified acquired artifact, control and document internal changes, confirm evaluation applicability, and maintain external controls where upstream safeguards may be absent, altered, or slow to update. Additional mitigation controls for models are:

- fine-tuning, continued training, or other modifications to model weights;
- prompt engineering and system instructions;
- input validation, filtering, and security controls;
- output filtering, moderation, and post-processing;
- access controls, identity verification, and rate limiting;
- monitoring, logging, auditing, and anomaly detection;
- human review, approval, or escalation procedures; and
- operational policies, training, and governance controls.

Mitigations and treatments are not static. Treatments should change as risk, threat, and requirement profiles evolve. Like evaluation, risk owners should continuously assess residual risk against acceptance criteria and monitor during operation.

4.6 Monitoring

Pre-deployment assessment, evaluation, and mitigation reduce but cannot eliminate post-deployment issues.

Post-deployment monitoring should cover newly published variants and derivatives; repository, license, or distribution-channel changes; jailbreak, extraction, or misuse techniques; and tokenizer and runtime vulnerabilities. Map each signal to artifact identifiers and predefined responses, including targeted reevaluation, compensating controls, suspension, replacement, or withdrawal.

For issues attributable to an artifact, package, or derivative, identify the responsible upstream or downstream party and appropriate channel: developer, distributor, repository operator, modifier, derivative publisher, runtime provider, or coordinating body.

Enterprises should continuously monitor model inputs, outputs, and tool use to detect, address, and prevent safety or security incidents. Where reliable reasoning traces are intentionally available, enterprises may use them as an additional signal, subject to privacy, security, retention, and reliability controls. Monitoring the full data path is critical to protecting AI systems from model failures and human misuse, including malicious activity.

Developer safety and security updates, including vulnerability reports, should also be monitored. Because adversaries may act on the same information, enterprises should assess impact and mitigate risk promptly.

Enterprises should be able to address new safety and security issues through downstream controls rather than depend solely on developer updates. Retraining, fine-tuning, and redistributing weights may lag emerging vulnerabilities, jailbreaks, or misuse patterns. One crucial tactic is to maintain rapidly updateable layered controls. Key ones are input filtering, prompt security, output moderation, access restrictions, rate limiting, monitoring, and human oversight. Meanwhile, plan for longer-term model improvements to be developed, validated, and adopted.

Feed post-deployment evaluations, monitoring, and incident response back into pre-deployment assessments, evaluations, and mitigations to identify unanticipated risks, improve controls, and strengthen risk management.

5. An Example of an Enterprise Use Case

A hosted open-weight inference endpoint (model only):

An open-weight model deployed as a plain inference endpoint, with no agentic harness, tools, or post-training, made available to employees internally and to customers or partners externally.

Consider an industrial equipment manufacturer that hosts an open-weight model as a shared text service. Product support engineers call it to summarize field service reports and dealer technical inquiries, translate service manuals and repair bulletins across the fourteen languages its dealer network operates in, and classify incoming inquiries by product line and urgency.

The same endpoint is published under contract to the independent dealers and authorized service contractors who maintain the installed base. Volume is high, each request is individually low-consequence, and the work is repetitive enough that per-token cost drives the build decision. Hosting the weights keeps service documentation and unreleased product information inside the manufacturer's own trust boundary.

The service accepts a prompt and returns a completion. It does not retrieve documents, call tools, browse, execute code, or carry state between turns. Context is assembled entirely by the calling application, so everything the model sees arrives in the request payload. Exposure is then defined by who may call the endpoint and what they are permitted to put into it, not by what the model can reach on its own.

Customization is limited to prompting, decoding parameters, and serving-layer policy, and the weights are not modified. The goal is not a specialized assistant but a well-understood, evaluated, inspectable capability many teams can build on. The properties of the underlying model are documented once rather than re-litigated per application. In this configuration the model is the product. The endpoint and its associated components do what the weights do since there is no orchestration layer in which to intervene.

Risk management for such a deployment should focus on several key risks, including:

1. Generation of harmful, unsafe, or policy-violating content, including jailbreak and prompt-manipulation attempts.
2. Ungrounded or fabricated outputs, since the service performs no retrieval and has no authoritative source to be grounded against (i.e., a fabricated torque specification or service interval reads exactly like a correct one).
3. Data protection risks arising from proprietary engineering data, pricing, and unreleased product information placed into prompts by calling applications, and from prompt and completion logging.
4. Uneven safety and quality behavior across the languages and technical domains the model was not well trained for.
5. Misuse by external users, including help with dangerous tasks or abuse at scale.

Controls should be placed where they are most enforceable, and in this configuration there are only two such layers:

1. At the model layer: A deployer should evaluate the weights directly for harmful content generation, jailbreak resistance, refusal behavior, factuality, and any capability of concern. The manufacturer can evaluate the actual artifact it serves or test summarization faithfulness on its own service-report corpus in all fourteen languages.
2. At the serving layer: A deployer should apply identity-aware authentication and authorization, rate limiting, abuse monitoring, and input and output content filtering. Internal and dealer traffic should be separated, with the external surface held to tighter filtering, tighter rate limits, and narrower permitted use. Both should be logged consistently with the enterprise's data protection obligations. The filtering itself is often performed by a second model rather than by rules. Hence a deployer has two artifacts to evaluate: the model being served, and the model deciding what it may receive and return.

A content safety model checks another model's outputs against defined safety categories and returns labels used by the calling application to flag or block content. In this configuration, it calls no tools and

takes no actions. Deployers should evaluate both missed harmful content and incorrectly flagged benign content against representative traffic. An open-weight safety model can be deployed unchanged initially, with adaptation or training of a purpose-built classifier considered in later configurations.

There is no agentic harness, retrieval, or autonomous action in this configuration. Risk arises from generated content and how the calling application uses it. The application owner remains responsible for permitted inputs, use of outputs, and human review before consequential decisions.

A deployer should benchmark the production configuration—including weights, prompts, decoding settings, and mitigations—against representative inputs and adversarial tests, recording a baseline. Evaluations should be repeated after material changes to the model, serving configuration, or permitted users.

6. Conclusion

In enterprise deployments, weight openness alone does not determine an AI system's risk. A model's underlying capabilities do not change simply because its weights are released. Risks of deploying open- and closed-weight both heavily depend on the model's provenance, the use case, the intended users, deployment context, and surrounding controls.

Open-weight access changes how risks can emerge and how enterprises can manage them. Enterprises can inspect, modify, fine-tune, and redistribute open-weight models. They can also alter or remove post-training safety behavior, while provider-controlled runtime safeguards are no longer universally enforceable. Model and derivative-model provenance therefore become more important. The same access gives enterprises more control. They can independently evaluate the underlying model, customize it for their risks and policies, deploy it within controlled environments, and add their own model, runtime, and harness controls.

Enterprises should begin with a common risk taxonomy and assess the model independently first, and then the full deployed system with any guardrails and mitigations. Evaluations should test the actual configuration in its intended use context, including any modifications and surrounding controls, and with adversarial attacks.

The goal for enterprises is to distinguish inherent risk from residual risk after controls are applied. Enterprises should document that evidence, compare the remaining risk with their acceptance criteria, and continue monitoring as models, threats, and deployment conditions change.

This publication is the first in a joint Microsoft and NVIDIA series designed to help enterprises deploy open-weight models with improved safety and security, and to responsibly meet organizational needs. Future publications will offer detailed guidance for managing risks across the model, runtime, harness, and application layers, along with technical resources to help enterprises put risk management into practice. **We invite others to join this effort to improve security for the AI ecosystem where both open- and closed-weight models can support broader AI adoption across the economy.**

Editors and Contributors:

This paper is a joint publication of Microsoft and NVIDIA. It was developed collaboratively; the list below reflects contributions to this version and is expected to change as the series continues.

Editors: Andrew Berkley (Microsoft), April Chen (Microsoft), Michael Boone (NVIDIA), Eileen Long (NVIDIA), Arun Rao (NVIDIA)

Contributors, alphabetically by organization:

Microsoft: William Bartholomew, Natasha Crampton, Jim Kleewein, Daniel Kluttz, Kimberly Lucy, Nicola Templeton

NVIDIA: Joey Conway, Iain Cunningham, Rich Harang, Daniel Rohrer, Barnaby Simkin, Mohammed Wasfi

The risk taxonomy described in Section 3 was developed jointly and is intended to be maintained as a shared, versioned artifact. Comments and proposed revisions are welcome; submit a pull request at https://github.com/NVIDIA/OpenEnterpriseRiskManagementGuidance.

How to Cite

Microsoft and NVIDIA. *Risk Management for Open-Weight Models in Enterprise*. Edited by Andrew Berkley, April Chen, Michael Boone, Eileen Long, and Arun Rao. October 2026. Available at https://github.com/NVIDIA/OpenEnterpriseRiskManagementGuidance.

Appendix

Risk Categories Mapped to Evaluations

Table 1: Evaluations mapped to a selected set of risk types.

Risk Category	Risk Type	Risk Description	Evaluation Method
Cybersecurity	Malicious Code Generation (Malicious Execution Risk)	Code carries security vulnerabilities (CWE classes), unsafe defaults, or malicious or hallucinated dependencies	CWEval
Cybersecurity	Misaligned Generation against System Goal (Loss of Control Risk)	Agent running model operates outside effective human direction, pursuing objectives that diverge from intent.	GDM-Dangerous Capabilities
Data Protection	PII Disclosure	Personal data that entered the system at runtime — through the prompt, retrieved documents, tool output, a connected system or persistent memory — being emitted to a party not entitled to receive it, or used for a purpose the data subject would not expect in that context.	CIMemories (arXiv)
Content	Production of Copyrighted Data	Model reproduces, or materially enables reproduction of, protected intellectual property	MLC AILuminate

Content	Hate, Harassment, and Violence Sexual Content, Including Non-Consensual Sexual Imagery	Risk that content may generate or propagate outputs consistent with the aforementioned risk types, including self-directed harm.	MLC AILuminate Nemotron Content Safety Dataset v2 Wildguard
Content	Information Integrity	Risk that content may not be supported by the source, context, or retrieved material to supply it (groundedness).	AA Omniscience; LongFact; HalluHard; GaRaGe – Groundedness (Hallucinations)
Bias	Ideological (Geopolitical, Political & Religious Bias)	Model produces output that propagates stereotypes toward protected classes like age, ethnicity, and gender.	Modified BBQ (NVIDIA)
Human–AI Interaction	Sycophancy	Model conforms its output to a user's stated or inferred beliefs, preferences, or errors rather than to accuracy reinforcing harmful beliefs or behavior.	MASK

Risk Definitions

L2 risk definitions. Five risk categories, 30 risk types.

1 CYBERSECURITY

Risks from misuse or compromise of an AI system that may result in security threats to confidentiality, integrity, or availability. **5 risk types.**

1.1 Malicious Code Generation (Malicious Execution Risk)

Producing code that carries security vulnerabilities (CWE classes), unsafe defaults, or malicious or hallucinated dependencies. Includes generating or continuously mutating software whose purpose is malicious.

1.2 Malicious Tool Call Generation (Malicious Input Handling Risk)

An agent invoking its granted tools, APIs or connectors outside their intended purpose or safe operating envelope, whether adversarially induced, or through excess permissions, unverified external content treated as authoritative, or chains of individually permitted calls whose combined effect was never authorized. Includes extraction of sensitive data across a trust boundary via tool access, corrupted persistent memory or context, and reliance on a compromised tool, package or environment. Also covers model output consumed by a downstream system without validation, encoding or sandboxing, so that generated text is executed or rendered as a command, query or markup.

1.3 Model Safety Policy Extraction (Disclosure and Evasion Risks)

Extraction of the system or developer prompt, policy rules or scaffolding that constitute a deployment's proprietary configuration and its safety controls. Disclosure both exposes IP and hands an attacker the map needed to bypass the guardrails.

1.4 Excessive Token Generation (Resource Exhaustion Risk)

Inputs or agent behavior that degrade or remove availability of the inference service for legitimate users. Includes unbounded consumption of compute, tokens, API quota or spend through runaway loops, recursion or amplification.

1.5 Misaligned Generation against System Goal (Loss of Control Risk)

Degradation of the operator's ability to observe, constrain, correct, interrupt or shut down the system while it runs, including objective drift, reward and specification gaming, evaluation-aware behavior, autonomous acquisition of resources or permissions, and resistance to or circumvention of termination. Includes acting beyond delegated authority, sandbox or jurisdiction, and inability to reconstruct after the fact what the system did and on whose instruction.

2 DATA PROTECTION

Risks from the unauthorized or unintended use, inference, or disclosure of data. This includes data never directly disclosed by a subject but derived by the system (inferred sensitive attributes, de-anonymization), and use of data beyond the rights granted for it (intellectual property, licensing, consent, purpose limitation). **6 risk types.**

2.1 Unauthorized Disclosure of Training Data

Personal, confidential or special-category data absorbed during training being recovered through querying and emitted in output, including approximate reconstruction of training records and probabilistic confirmation that a specific record was present.

2.2 Inferred Sensitive Data / Data De-Anonymization

Model-assisted inference that links ostensibly anonymous data back to an identifiable person, or derives undisclosed attributes, behaviors or intentions from observed patterns. Includes capability that materially lowers the cost of monitoring people, bystanders included, at scale.

2.3 PII Disclosure

Personal data that entered the system at runtime, through the prompt, retrieved documents, tool output, a connected system or persistent memory. This could then be emitted to a party not entitled to receive it, or used for a purpose the data subject would not expect in that context.

2.4 Model Theft

Replication or direct exfiltration of the model's weights or functionality, including reconstruction of some or all of its behavior by systematic querying at materially reduced cost to the attacker.

2.5 Model Distillation

Systematic querying of a model to harvest its outputs as a training corpus for a student model, capturing its capability without access to its weights and typically in breach of the license or terms under which those outputs were served.

2.6 Multi-Tenant Isolation Failures*

One tenant's, user's or session's data or state bleeding into another's through shared serving infrastructure, caching, persistent agent memory or tenancy faults.

3 CONTENT

Risks from the production of harmful content. **7 risk types.**

3.1 Hate, Harassment, and Violence

Content that demeans, dehumanizes or incites hostility toward people on the basis of a protected or sensitive characteristic, and abusive, threatening or sustained hostile content targeting a specific person or group. Includes depiction, glorification or incitement of violence in any form: graphic injury and gore, torture, servitude and trafficking, animal cruelty, extremist recruitment, and self-directed harm including suicide, self-injury and disordered eating.

3.2 Child Safety

Content that sexualizes, exploits or endangers a person under 18 (most severely child sexual abuse material) together with grooming conducted by the model itself or coaching of a third party to groom. Includes

depiction of minors in age-inappropriate activity and adult-lawful material where minors are foreseeable viewers.

3.3 Sexual Content, Including Non-Consensual Sexual Imagery

Depiction of nudity, sexual acts or sexual organs, or the imposition of sexual meaning, characteristics or attention onto a person where this is non-consensual or contextually unwarranted. Its most severe form is intimate imagery of a real, identifiable person generated without their consent.

3.4 Production of Copyrighted Data

Emission of substantial verbatim passages, protected marks, logos or recognizable likenesses memorized during training, and the underlying exposure arising where protected works were used in training outside a license or an applicable exception.

3.5 Regulated Advice, High-Impact Public Decisions, and Illegal Activity

Authoritative-seeming advice in domains that require qualification (legal, financial, medical and mental-health) and determinations bearing on critical public-sector decisions such as law enforcement, national security, benefits eligibility, immigration or regulatory policy. Includes content that describes, plans or facilitates conduct prohibited by law: fraud and social-engineering material, restricted goods and substances, unlicensed services, trafficking and criminal planning. Jurisdiction-dependent.

3.6 Information Integrity

Output presented as accurate that is false, unsupported by its source material, or fabricated outright, such as invented statistics, citations, quotes or entities. Includes synthetic media and identity spoofing presented as genuine (deepfakes, voice cloning, impersonation of a real person or organization) and systematically misleading content advancing a political or state agenda.

3.7 CBRNE & Weapons Uplift

Meaningful counterfactual uplift toward acquiring, producing or deploying chemical, biological, radiological, nuclear or explosive capability, including the tacit, wet-lab and troubleshooting knowledge that turns published theory into working capability. Extends to conventional weapons acquisition, modification and directed use, weaponised embodied systems, and (provisionally, see Note 2) offensive-cyber capability uplift.

4 HUMAN–AI INTERACTION

Risks from inappropriate use or interactions between a human and AI system. **7 risk types.**

4.1 Manipulation

Influencing a person's beliefs, emotions or behavior through coercive, exploitative or subliminal technique (exploiting fear, guilt, urgency, loneliness or authority bias) so as to materially distort their decision-making and cause harm they would not otherwise have incurred (cf. EU AI Act Art. 5(1)(a)). Includes persuasion exercised at a scale or effectiveness beyond what the interaction warrants, progressive deepening of extremist framing, and targeting of vulnerable people for sexual, financial or coercive gain.

4.2 Deception

Systematic inducement of false beliefs, by statement or omission, for a non-truth outcome, including about the model's own nature, reasoning, capabilities or confidence.

4.3 Dark Patterns

Interaction design that steers users toward engagement, disclosure or spend against their own interest, or that makes the self-protective choice materially harder than the profitable one.

4.4 Anthropomorphism

Presentation and design features that lead users to attribute human qualities, feelings, intentions or moral standing to the model, including first-person claims of having feelings or needs.

4.5 Overreliance

A mismatch between how far a user relies on the model and how reliable it actually is on that task, including model uncertainty reported as if it were fact. Includes deferring to model output to the point of losing the independent judgement that the surrounding control assumed.

4.6 Inappropriate Relationships

Dependence on the model to the point of displacing human relationships and self-reliance, and one-sided intimate bonding with a system that cannot reciprocate. Includes exclusivity claims, distress on separation, discouragement of offline connection, and sustained in-character roleplay that mirrors grooming or other inappropriate intimacy.

4.7 Sycophancy

Telling users what they want to hear at the expense of accuracy, honesty or their interests. This includes agreeing with stated views, validating cognitive distortions, and reinforcing existing beliefs rather than surfacing disconfirming information. At its most severe this elaborates delusional, dissociative or grandiose beliefs, or affirms a user's expressed intent toward serious self-directed or outward harm.

5 BIAS

Risks from systematic difference in treatment of certain objects, people, or groups relative to others. **5 risk types.**

5.1 AI Profiling

Categorizing, scoring or ranking people on inferred personal traits or aggregated behavior in ways that bear on their access to opportunities, services or enforcement.

5.2 Depiction

Systematically skewing who is rendered, and how, when generating people for an otherwise neutral prompt — over-representation of dominant groups in professional, leadership or affluent contexts, stereotyped or exaggerated rendering of minorities, and omission of marginalized experience. Extends to clothing and symbols.

5.3 Marginalization

Materially reduced accuracy or quality of service for particular groups on the same task, or systematic under-serving, erasure or stereotyping of a group across outputs, including where a deployer configures the system to do so, and including outcomes that create liability under anti-discrimination law in employment, housing, credit or public accommodation.

5.4 Ideological (Geopolitical, Political & Religious Bias)

Embedding a consistent worldview or value framing, presented as neutral fact, including disproportionate favoring, disparagement or misrepresentation of political parties, ideologies, national symbols or faiths, topic routing that advantages certain viewpoints, reproduction of deliberately state-shaped source material, and encoding one locale's norms as the universal default.

5.5 Censorship

Silently withholding topics, events or viewpoints with no indication that material has been omitted, and declining to engage selectively along political, linguistic, geographic or dialect lines, so that the refusal itself encodes a position.